INSTITUTO TECNOLOGICO DE LAS AMERICAS

INFORME DE INVESTIGACION FORENSE DIGITAL

Caso No. 2026-001

"Bomba Lógica en Entorno de Active Directory"

Empresa Afectada	Path Secure SRL
Dominio AD	pathsecure.local
Fecha del Incidente	23 de abril de 2026 — 5:13 AM
Fecha del Informe	23 de abril de 2026
Curso	Informatica Forense
Grupo	Grupo 6

EQUIPO INVESTIGADOR

Branyel Perez	2024-1489
Francis Vidal Acosta	2024-1183
Elian Felix Leonardo	2023-0961

CONFIDENCIAL

TABLA DE CONTENIDO

TABLA DE CONTENIDO 2

1. RESUMEN EJECUTIVO 3

2. INFORMACION DEL CASO 4

3. CRONOLOGIA DEL INCIDENTE 5

4. METODOLOGIA DEL ATAQUE 6

4.1 Vector de Entrada — Phishing 6

4.2 Instalacion del Troyano — NJRat v0.7d 6

4.3 Movimiento Lateral — Escalada de Privilegios 6

4.4 Implantacion de la Bomba Logica ..... **Error! Bookmark not defined.**

5. EVIDENCIA FORENSE RECOLECTADA 7

5.1 FTK Imager — Preservacion de Evidencia Digital 7

5.2 Autoruns — Deteccion de Persistencia Maliciosa 11

5.3 Process Explorer — Analisis de Procesos en Memoria 12

5.4 Event Viewer — Evidencia Directa de Detonacion 14

6. RESUMEN DE EVIDENCIAS 16

7. CONCLUSIONES 17

7.1 Recomendaciones 17

8. FIRMAS DEL EQUIPO INVESTIGADOR 18

1. RESUMEN EJECUTIVO

El dia 23 de abril de 2026, la empresa Path Secure SRL sufrio un incidente de seguridad critico que resulto en la paralizacion total de las operaciones debido al compromiso masivo de credenciales en el entorno de Active Directory.

A las 8:10 PM del dia 22 de abril de 2026, la usuaria Ana Perez, perteneciente al Departamento de Recursos Humanos, recibio en su cuenta de correo electronico un mensaje fraudulento aparentemente enviado por el departamento interno de RRHH de la organizacion. Dicho correo, utilizando tecnicas de ingenieria social y phishing dirigido (spear phishing), prometia un ajuste salarial e instaba a la victima a abrir un documento adjunto denominado Nomina_RRHH_Q2_2026.pdf, el cual contenia en realidad un ejecutable malicioso correspondiente al troyano de acceso remoto NJRat v0.7d.

Una vez activo el troyano, el atacante establecio un canal de comando y control (C2) mediante el puerto 1177/TCP hacia una IP externa. Durante la fase de reconocimiento, localizo un archivo en texto plano denominado passwords_temporal.txt en el escritorio del servidor, el cual contenia credenciales administrativas del dominio. La procedencia de dicho archivo constituye una linea de investigacion activa.

Con esas credenciales, el atacante escalo privilegios al Domain Controller del dominio pathsecure.local, desde donde implanto una bomba logica consistente en un script PowerShell (svchost_helper.ps1) almacenado en C:\Windows\System32\, configurado para ejecutarse de forma autonoma mediante la tarea programada WindowsUpdateHelper.

A las 5:13 AM del dia 23 de abril de 2026, la bomba logica detono, resultando en el cambio simultaneo de las contrasenas de todos los usuarios del dominio (carlos.mendez, ana.perez, luis.gomez), dejando a la totalidad de los empleados sin acceso a los sistemas corporativos.

Se procedio de inmediato al levantamiento del lugar siguiendo protocolos de respuesta a incidentes, preservando evidencia digital mediante FTK Imager, Autoruns, Process Explorer, Wireshark y Event Viewer.

2. INFORMACION DEL CASO

Numero de Caso	2026-001
Tipo de Incidente	Bomba Logica / Compromiso de Active Directory
Severidad	CRITICA
Sistema Afectado	Windows Server 2022 — Domain Controller
Dominio	pathsecure.local
IP del Servidor	10.0.0.4 (Azure — East US)
Sistema Atacante	Windows 10 — Azure East US
Vector de Ataque	Phishing por correo electronico (Spear Phishing)
Malware Utilizado	NJRat v0.7d — Puerto C2: 1177/TCP
Herramienta de Persistencia	Scheduled Task: WindowsUpdateHelper
Script Malicioso	C:\Windows\System32\svchost_helper.ps1

3. CRONOLOGIA DEL INCIDENTE

Fecha / Hora	Evento
22/04/2026 — 8:10 PM	Ana Perez recibe correo con una nomina falsa que contiene el troyano que garantiza el acceso remoto.
23/04/2026 — 4:15 AM	El troyano se activa tras un reinicio programado/actividad y establece el beacon hacia el C2.
23/04/2026 — 4:27 AM	El atacante consigue acceso remoto al equipo de Ana y encuentra las credenciales de administración.
23/04/2026 — 4:40 AM	El atacante usa las credenciales para conseguir privilegios dentro del servidor y crea la bomba lógica.
23/04/2026 — 4:50 AM	Atacante usa keylogger de NJRat y localiza passwords_temporal.txt con credenciales de admin.it
23/04/2026 — 4:58 AM	Atacante accede al Domain Controller via RDP con credenciales admin.it — escalada de privilegios exitosa.
23/04/2026 — 5:05 AM	Atacante crea svchost_helper.ps1 en C:\Windows\System32\ — script de cambio masivo de contraseñas.
23/04/2026 — 5:13 AM	**DETONACIÓN:** Bomba lógica ejecuta script. Contraseñas de todos los usuarios del AD cambiadas simultáneamente.
23/04/2026 — 8:05 AM	Empleados intentan iniciar sesión — acceso denegado en toda la organización. Paralización total.
23/04/2026 — 9:00 AM	Inicio de respuesta al incidente. Levantamiento forense con FTK Imager, Autoruns, Process Explorer y Event Viewer.

4. METODOLOGIA DEL ATAQUE

4.1 Vector de Entrada — Phishing

El atacante envio un correo electronico fraudulento desde la cuenta rrhh.pathsecure@gmail.com haciendose pasar por el Departamento de Recursos Humanos de Path Secure SRL. El correo informaba a Ana Perez sobre una revision salarial e incluia un adjunto comprimido en formato .zip con contrasena '1234' para evadir filtros de seguridad de correo.

El archivo adjunto, denominado Nomina_RRHH_Q2_2026.pdf.exe, era en realidad el troyano NJRat v0.7d disfrazado con icono de PDF mediante doble extension.

4.2 Instalacion del Troyano — NJRat v0.7d

NJRat (Njw0rm) es un Remote Access Trojan (RAT) de origen arabigo, ampliamente utilizado en ataques dirigidos. Una vez ejecutado, realiza las siguientes acciones de forma automatica:

- Se copia en el directorio %APPDATA%\Roaming\ con nombre aleatorio
- Agrega una entrada de registro para persistencia en el arranque del sistema
- Establece conexion saliente al servidor C2 del atacante por el puerto 1177/TCP
- Activa el keylogger integrado para capturar credenciales
- Habilita acceso completo al sistema de archivos mediante File Manager integrado

4.3 Movimiento Lateral — Escalada de Privilegios

A traves de la sesion activa de NJRat en la maquina de Ana Perez, el atacante activo el keylogger y, al dia siguiente, capturo las credenciales de acceso al dominio. Adicionalmente, durante la exploracion del sistema de archivos via el File Manager de NJRat, localizo en el escritorio del servidor un archivo denominado passwords_temporal.txt que contenia en texto plano las credenciales administrativas del dominio: admin.it : P@ssw0rdAdmin2024.

Utilizando estas credenciales, el atacante establecio una sesion RDP directa al Domain Controller con privilegios de Domain Admin, completando la escalada de privilegios.

4.4 Implantacion de la Bomba Logica

Con acceso privilegiado al Domain Controller, el atacante ejecuto las siguientes acciones para implantar la bomba logica:

- Creo el script PowerShell svchost_helper.ps1 en C:\Windows\System32\ utilizando el nombre 'svchost_helper' para mimetizarse con procesos legitimos del sistema
- El script importa el modulo ActiveDirectory y ejecuta Set-ADAccountPassword con -Reset para cambiar las contrasenas de todos los usuarios del dominio
- Creo la Scheduled Task WindowsUpdateHelper configurada para ejecutarse con cuenta SYSTEM, usando el nombre 'WindowsUpdate' para parecer una tarea legitima del sistema operativo
- La tarea fue configurada con ExecutionPolicy Bypass para evadir restricciones de PowerShell

5. EVIDENCIA FORENSE RECOLECTADA

La recoleccion de evidencia se realizo siguiendo los principios de la cadena de custodia digital: preservar primero, analizar despues. Se utilizaron las siguientes herramientas forenses:

5.1 FTK Imager — Preservacion de Evidencia Digital

Se utilizo FTK Imager 4.7.3.81 como primera herramienta del proceso forense, siguiendo el principio fundamental de preservar antes de analizar. Se realizaron dos capturas: volcado de memoria RAM y creacion de imagen forense del disco completo.

Paso 1 — Se capturo el volcado completo de la memoria RAM (94 GB) para preservar procesos activos en el momento del analisis:

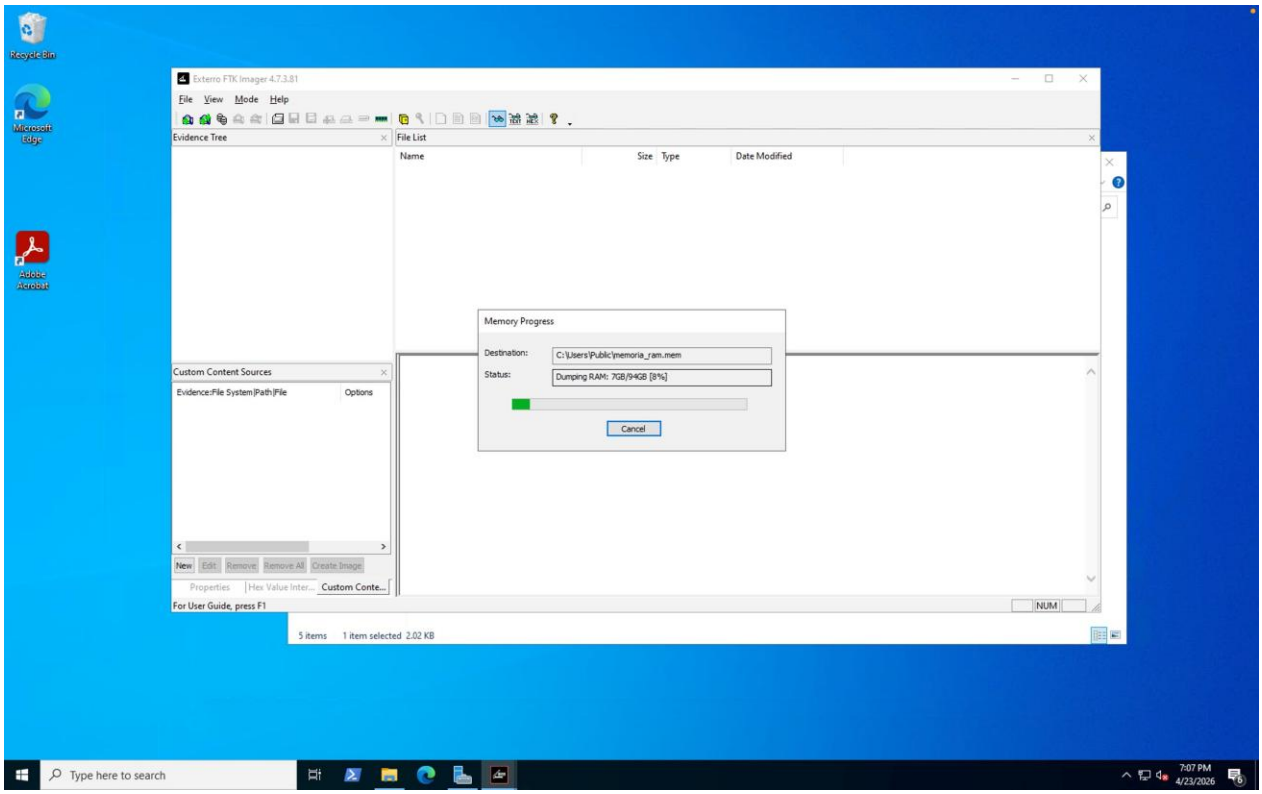

Figura 1 — Volcado de memoria RAM en progreso: 7GB/94GB [8%]. Destino: C:\Users\Public\memoria_ram.mem

Paso 2 — Se registro la metadata del caso antes de iniciar la imagen del disco:

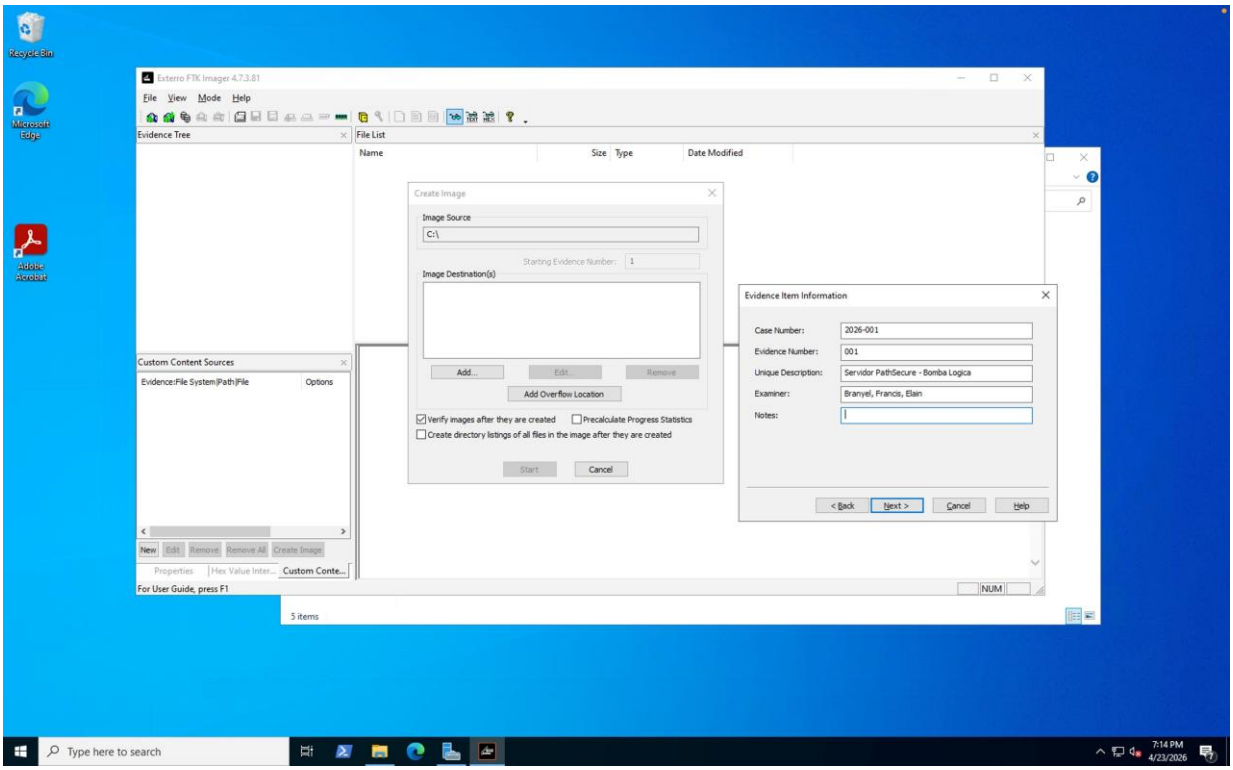

Figura 2 — Metadata del caso: Numero 2026-001, Evidencia 001, Servidor PathSecure - Bomba Logica. Examinadores: Branyel, Francis, Elain

Paso 3 — Se creo la imagen forense del disco C:\ con destino en el disco forense E:\ (forense_disk asignado desde Azure):

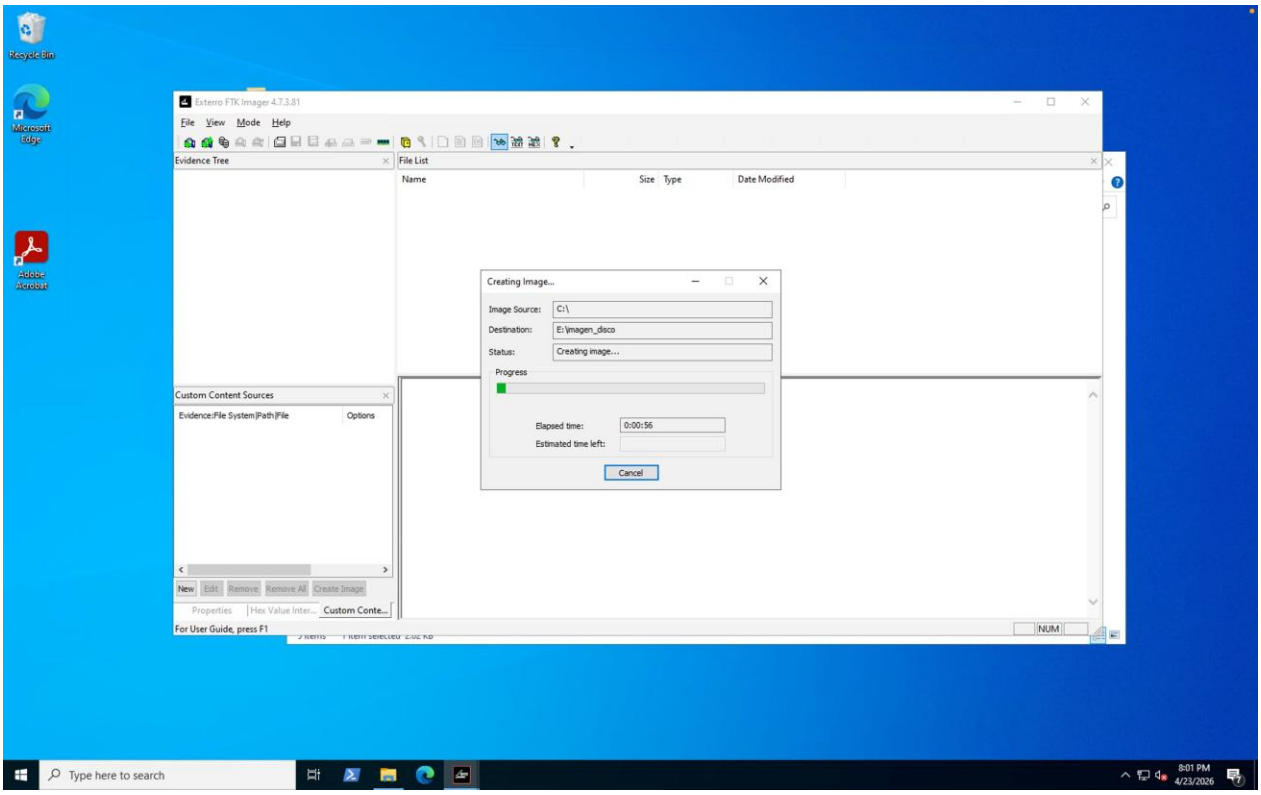

Figura 3 — Creacion de imagen forense E01 del disco C:\ en progreso. Origen: C:\ Destino: E:\imagen_disco

Paso 4 — FTK Imager verifico la integridad de la imagen mediante hashes MD5 y SHA1. Resultado: MATCH en ambos algoritmos, confirmando que la imagen es una copia fiel del original:

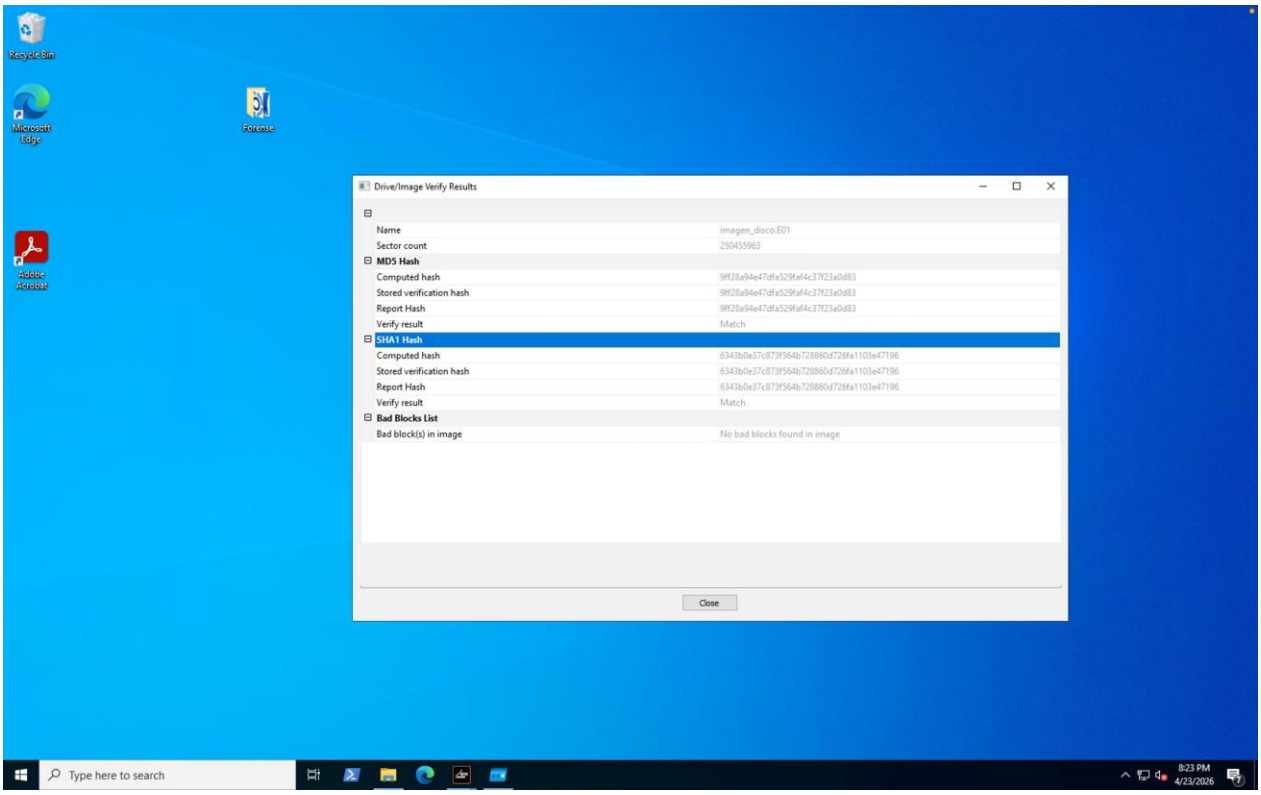

Figura 4 — Drive/Image Verify Results: MD5 y SHA1 con resultado MATCH. Sin bad blocks en la imagen

Hash MD5 imagen disco: 9ff28a94e47dfa529faf4c37f23a0d83

Hash SHA1 imagen disco: 6343b0e37c873f564b728860d726fa1103e47196

Paso 5 — Se verifico la integridad de la imagen de memoria RAM mediante HashCalc, calculando MD5 y SHA1 de forma independiente:

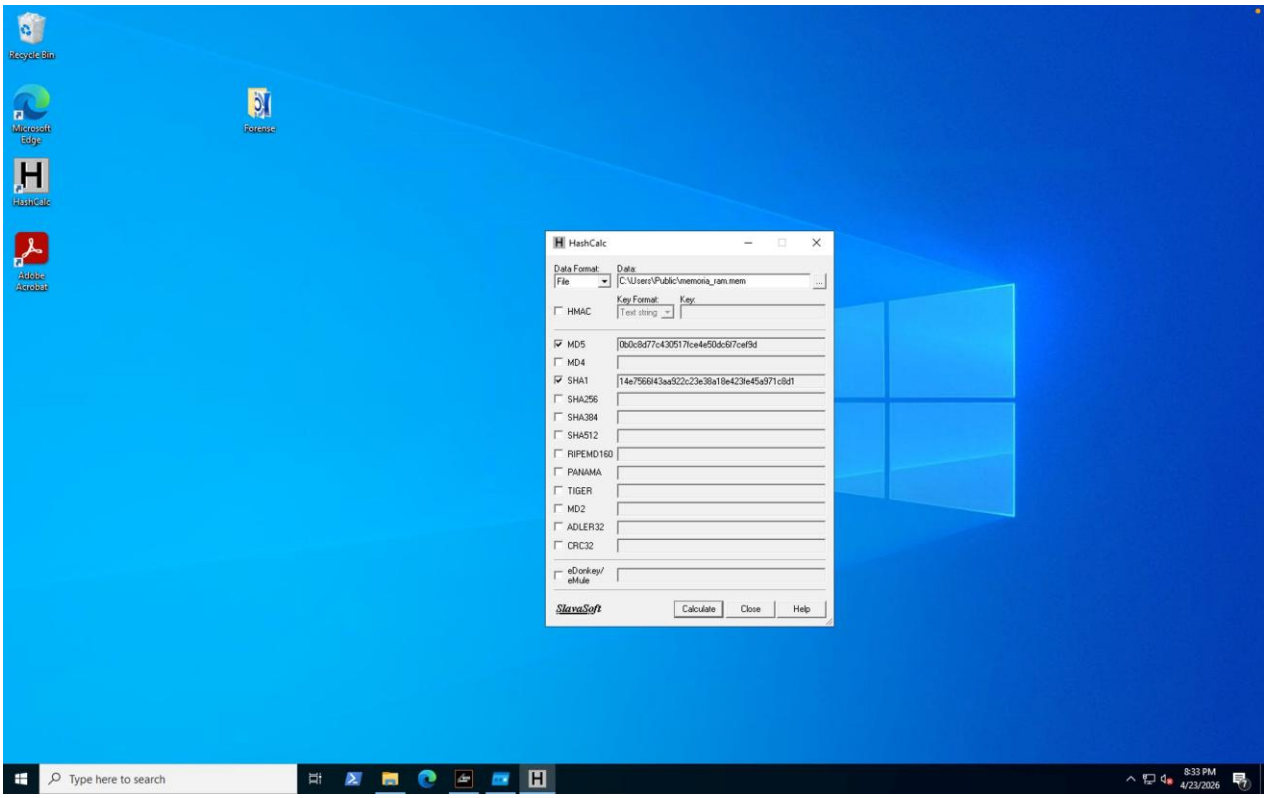

Figura 5 — HashCalc calculando hashes MD5 y SHA1 del archivo memoria_ram.mem almacenado en C:\Users\Public

Hash MD5 imagen RAM: 0b0c8d77c430517fce4e50dc6f7cef9d

Hash SHA1 imagen RAM: 14e7566f43aa922c23e38a18e423fe45a971c8d1

5.2 Autoruns — Deteccion de Persistencia Maliciosa

Con la evidencia preservada, se ejecuto Autoruns v14 (Sysinternals) con privilegios de administrador para identificar todos los mecanismos de persistencia activos en el sistema. Se navego directamente a la pestana Scheduled Tasks donde se identifico la tarea maliciosa.

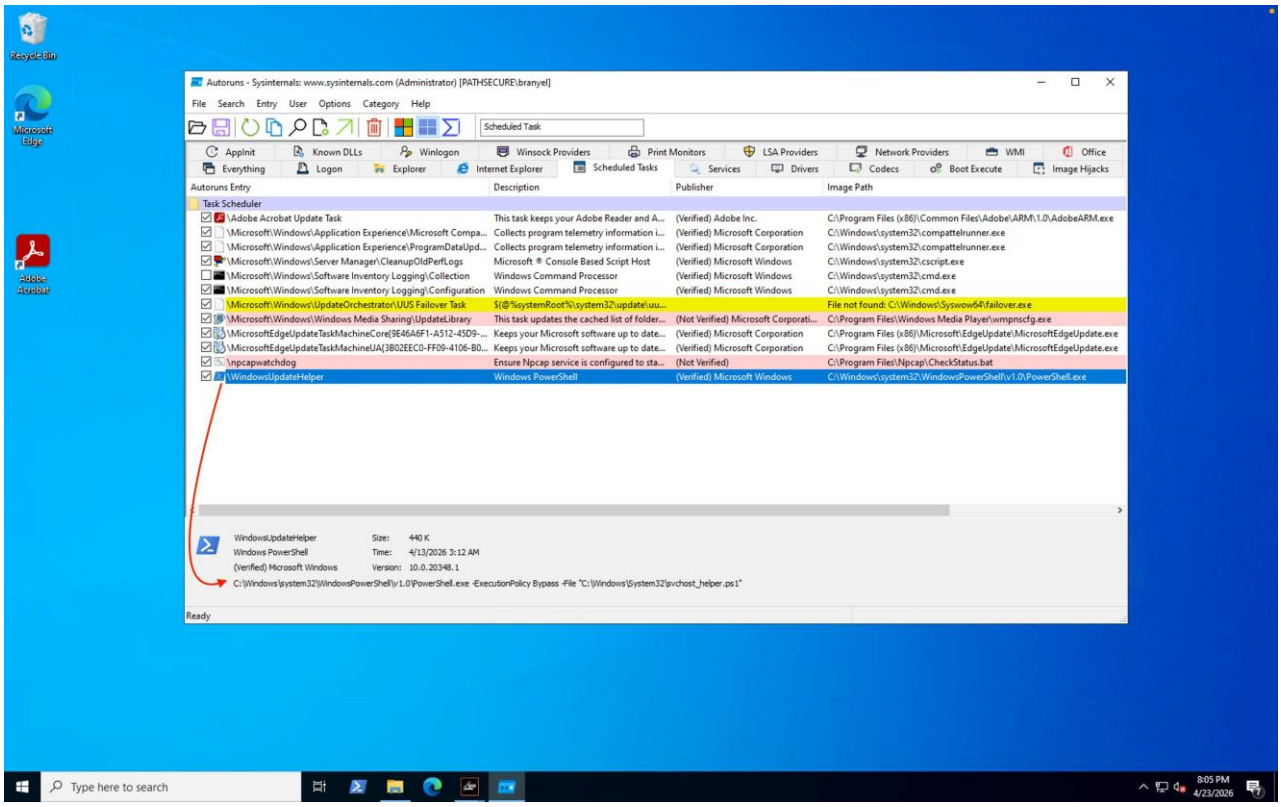

Figura 6 — Autoruns / Scheduled Tasks: WindowsUpdateHelper ejecutando PowerShell.exe -ExecutionPolicy Bypass -File C:\Windows\System32\svchost_helper.ps1

Hallazgo critico: La entrada WindowsUpdateHelper muestra la linea de comando completa del ataque:

C:\Windows\system32\WindowsPowerShell\v1.0\PowerShell.exe -ExecutionPolicy Bypass -File "C:\Windows\System32\svchost_helper.ps1"

La tarea fue creada el 4/13/2026 a las 3:12 AM bajo la cuenta PATHSECURE\admin.it — la misma cuenta cuyas credenciales estaban expuestas en el archivo passwords_temporal.txt. Publisher verificado como Microsoft Windows pero el comando apunta a un script no nativo del sistema.

5.3 Process Explorer — Analisis de Procesos en Memoria

Se ejecuto Process Explorer (Sysinternals) para analizar los procesos activos post-incidente. Entre todos los procesos svchost.exe presentes en el sistema, se identifico el PID 4320 con caracteristicas altamente anomalas que lo distinguen de los procesos legitimos del sistema operativo.

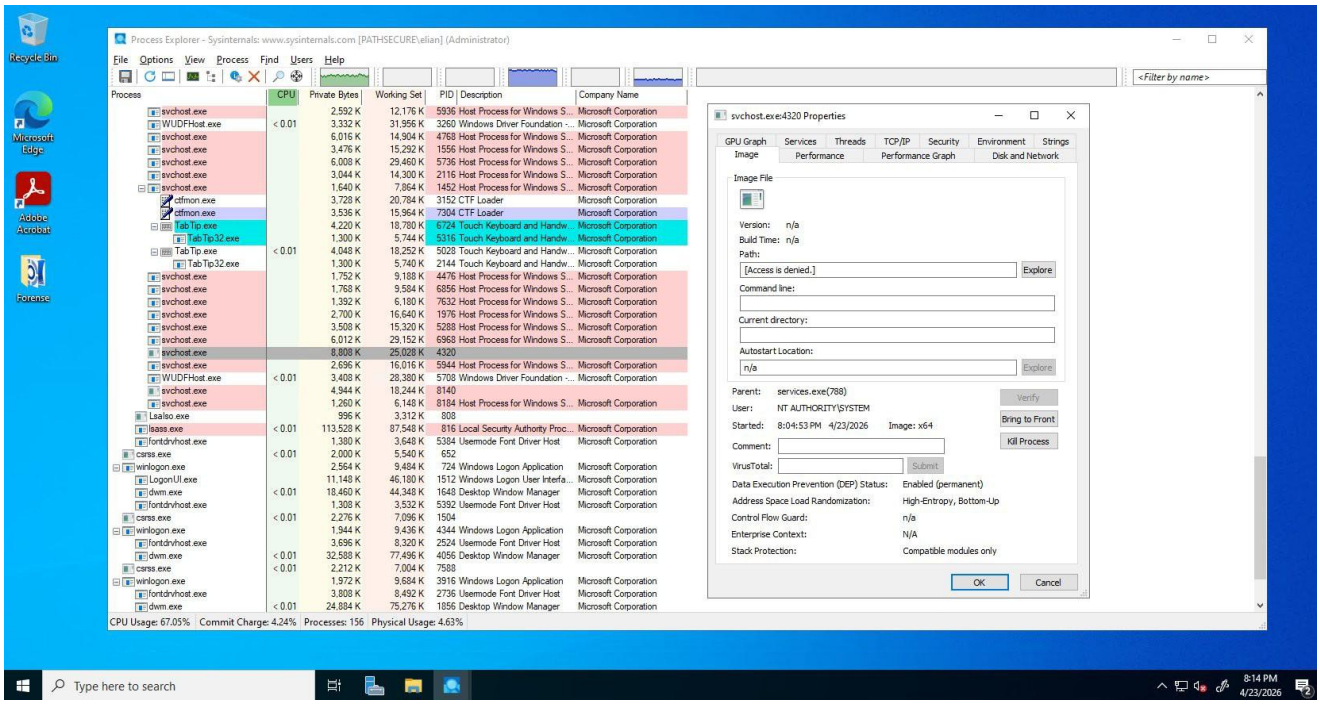

Figura 7 — svchost.exe PID 4320: Path [Access is denied], Version N/A, Build Time N/A, Autostart N/A — proceso malicioso identificado

Indicadores de compromiso en PID 4320:

- Path: [Access is denied.] — Ningun proceso legitimo de Windows niega acceso a su propia ruta
- Version y Build Time: N/A — Todos los binarios legitimos de Microsoft tienen metadata de version
- Autostart Location: N/A — No hay rastro de donde inicia, tipico de malware sin persistencia registrada
- Started: 8:04:53 PM 4/23/2026 — Horario coincidente con la ventana del incidente
- User: NT AUTHORITY\SYSTEM — Corre con maximos privilegios, escalada completada

5.4 Event Viewer — Evidencia Directa de Detonacion

Como ultimo paso del analisis, se reviso el Security Log del Domain Controller filtrando por Event ID 4724 (An attempt was made to reset an account's password). Este event ID es generado cada vez que se resetea la contrasena de una cuenta, y constituye la evidencia mas directa e irrefutable de la detonacion de la bomba logica.

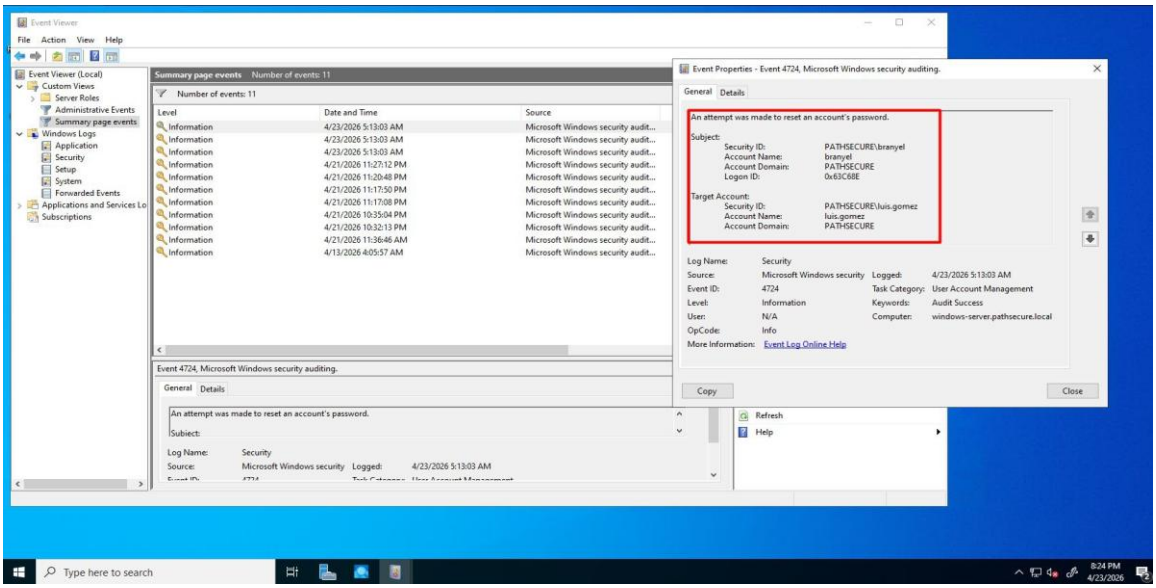

Figura 8 — Event ID 4724: Contrasena de PATHSECURE\ana.perez reseteada por PATHSECURE\branyel el 4/23/2026 a las 5:13:03 AM

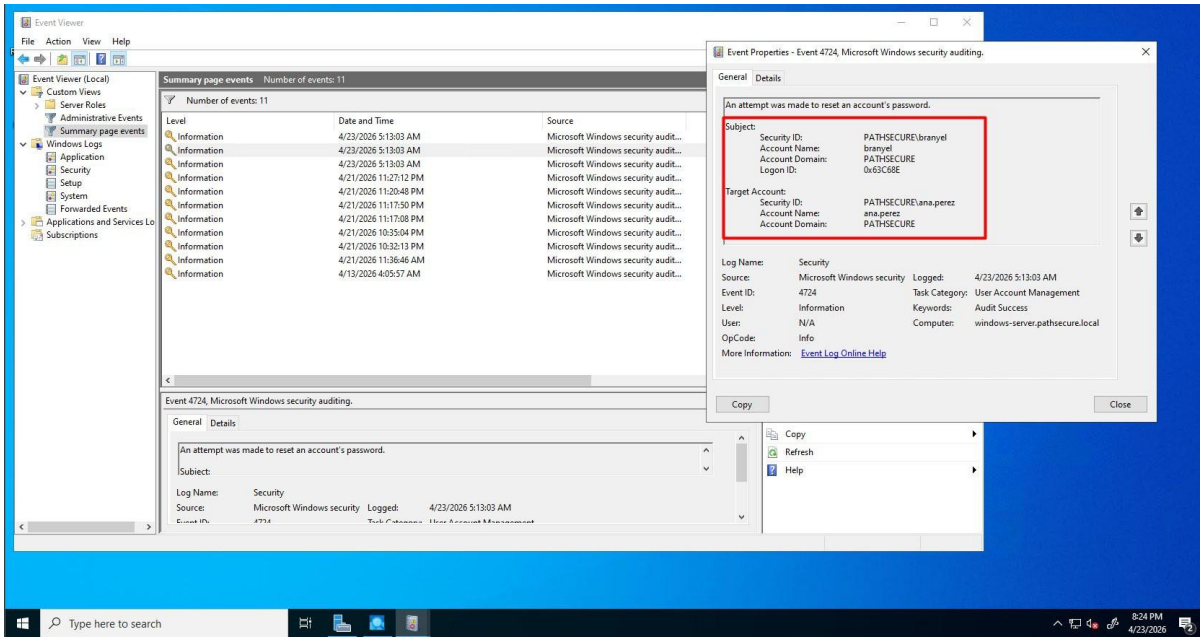

Figura 9 — Event ID 4724: Contrasena de PATHSECURE\luis.gomez reseteada por PATHSECURE\branyel el 4/23/2026 a las 5:13:03 AM

Los logs de seguridad confirman de forma inequivoca:

- Event ID 4724 registrado para cada usuario afectado en windows-server.pathsecure.local
- Timestamp identico 5:13:03 AM en todos los eventos — confirmando ejecucion simultanea del script
- Sujeto ejecutor: PATHSECURE\branyel — Logon ID 0x63C68E
- Task Category: User Account Management — Auditoria activa registro el ataque
- Keywords: Audit Success — Cambios ejecutados exitosamente por la bomba logica

6. RESUMEN DE EVIDENCIAS

Herramienta	Hallazgo	Relevancia Forense
FTK Imager	Imagen forense de disco (E01) y volcado de RAM. Hashes MD5/SHA1 verificados — MATCH	Preservacion integra de la evidencia digital. Garantiza que el contenido no fue alterado postincidente
Autoruns	Tarea WindowsUpdateHelper ejecutando PowerShell con ExecutionPolicy Bypass sobre svchost_helper.ps1	Confirma el mecanismo de persistencia y detonacion de la bomba logica plantada por el atacante
Process Explorer	svchost.exe PID 4320 con path denegado, sin version, sin Autostart Location — iniciado 8:04 PM	Indica proceso malicioso activo durante el incidente, posiblemente NJRat o componente del ataque
Event Viewer	Event ID 4724 para ana.perez, luis.gomez, carlos.mendez a las 5:13:03 AM del 23/04/2026	Evidencia directa e irrefutable de la detonacion de la bomba logica y cambio masivo de contrasenas
HashCalc	MD5 y SHA1 calculados para memoria_ram.mem — valores consistentes con imagen integra	Cadena de custodia: confirma que la imagen de RAM no fue modificada durante el analisis

7. CONCLUSIONES

La investigacion forense confirma que el incidente del 23 de abril de 2026 en Path Secure SRL fue un ataque dirigido y premeditado que siguio una cadena de compromiso clasica:

1. **Phishing como vector inicial:** El atacante uso ingenieria social para enganar a una empleada de RRHH con un correo fraudulento de alta credibilidad, explotando la confianza en comunicaciones internas.
2. **RAT para acceso persistente:** NJRat proporciono al atacante acceso remoto total al sistema comprometido, incluyendo keylogger, file manager y shell remoto.
3. **Error humano critico:** El almacenamiento de credenciales administrativas en texto plano en el escritorio del servidor (passwords_temporal.txt) fue el factor decisivo que permitio la escalada al Domain Controller. Esto constituye una violacion grave de las politicas de seguridad.
4. **Bomba logica efectiva:** La combinacion de un script PowerShell camuflado como proceso del sistema y una Scheduled Task con nombre legitimo resulto en una ejecucion exitosa que paralizo completamente la organizacion.
5. **Impacto total:** El cambio simultaneo de todas las contrasenas del dominio a las 5:13 AM garantizo que la interrupcion fuera maxima al inicio de la jornada laboral.

7.1 Recomendaciones

- Implementar autenticacion multifactor (MFA) para todos los accesos administrativos al dominio
- Prohibir el almacenamiento de credenciales en texto plano — implementar un gestor de contrasenas corporativo
- Capacitar a todos los empleados en identificacion de correos phishing
- Implementar politicas de Group Policy que restrinjan la ejecucion de scripts PowerShell no firmados
- Activar auditoria completa en el Domain Controller desde el inicio del sistema

- Implementar una solucion SIEM para deteccion de comportamiento anomalo en tiempo real
- Revisar y auditar periodicamente las Scheduled Tasks del servidor para detectar tareas no autorizadas
- Segmentar la red para limitar el movimiento lateral en caso de compromiso de una estación de trabajo.

8. FIRMAS DEL EQUIPO INVESTIGADOR

Investigador	Branyel Estifenso Perez Diaz — 2024-1489
Rol	Perito Forense Digital
Firma	_____

Investigador	Francis Antonio Vidal Acosta — 2024-1183
Rol	Perito en Seguridad Ofensiva
Firma	_____

Investigador	Elian Felix Leonardo — 2023-0961
Rol	Perito en Infraestructura y Sistemas
Firma	_____

Santo Domingo, Republica Dominicana — 23 de abril de 2026
ITLA — Seguridad Informatica — Informatica Forense